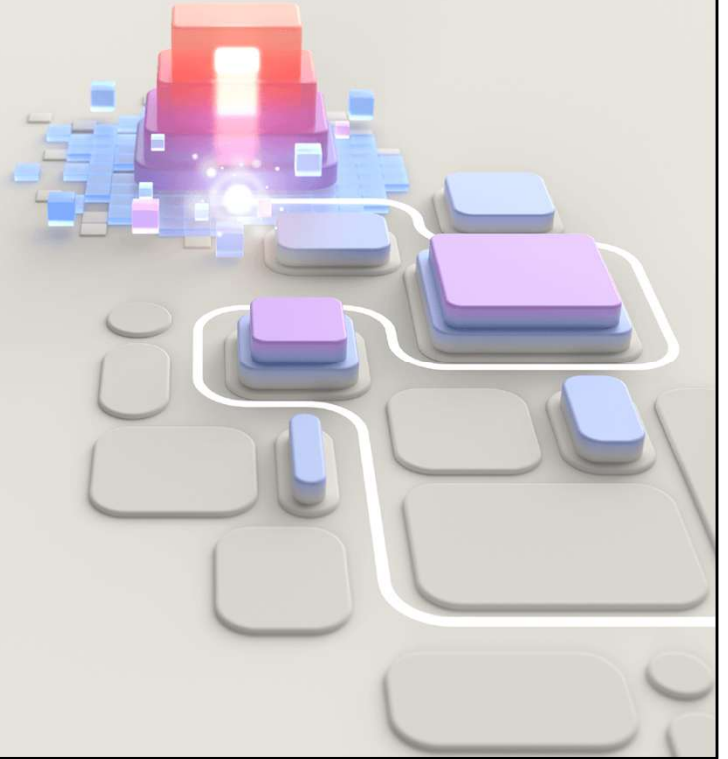




DP-300

Implement scalable database solutions using Azure SQL



© Copyright Microsoft Corporation. All rights reserved.

Implement a secure environment for a database service

<https://learn.microsoft.com/training/paths/implement-secure-environment-database-service/>

© Copyright Microsoft Corporation. All rights reserved.

This Learning Path explores the practices of securing your SQL Server Database as well as an Azure SQL database. This includes a review of the various SQL Server-based options as well as the various Azure options for securing Azure SQL Database as well as the databases with reside within Azure SQL Database. Students will learn why security is crucial when working with databases.

<https://learn.microsoft.com/training/paths/implement-secure-environment-database-service/>

Objectives



Understand the differences between Windows, SQL Server and Microsoft Entra authentication



Describe and configure both data-at-rest encryption solutions as well as data-in-transit encryption solutions



Implement a data sensitivity solution

© Copyright Microsoft Corporation. All rights reserved.

Configure database authentication and authorization

<https://learn.microsoft.com/training/modules/configure-database-authentication-authorization/>

© Copyright Microsoft Corporation. All rights reserved.

Azure SQL Database has several authentication options which are different from the authentication options of SQL Server. You'll learn about the differences between those authentication mechanisms.

Objectives



Authentication options for Azure SQL Database



Security principals



Roles in Azure SQL Database



Understand permissions within Azure SQL



Understand the concept of least privilege

© Copyright Microsoft Corporation. All rights reserved.

Azure AD authentication options



© Copyright Microsoft Corporation. All rights reserved.

Bilden sammanfattar autentiseringsalternativ för SQL Server i olika miljöer och visar tydligt att alternativen skiljer sig åt beroende på om databasen körs lokalt/on-prem eller som en Azure-tjänst. För en traditionell SQL Server finns två huvudval: **Windows Authentication** och **SQL Server Authentication**. Vid Windows Authentication hanteras inloggningsinformationen via katalogtjänsten – i sammanhanget kopplat till **Microsoft Entra ID** – vilket ger central identitetshantering och ofta bättre kontroll, exempelvis genom policies och Single Sign-On. Vid SQL Server Authentication lagras istället konton och lösenord i SQL Server (i master eller respektive användardatabas), vilket kan vara praktiskt men kräver mer aktiv hantering av säkerhet och lösenord.

För **Azure SQL Database** och **Azure SQL Managed Instance** finns också två huvudalternativ. Det ena är **Microsoft Entra Authentication**, där användare och grupper hämtas från Entra ID och autentiseringen sker via moderna identitetsfunktioner. Det andra är **SQL Server Authentication**, som fortfarande stöds och fungerar på liknande sätt som i klassisk SQL Server.

Budskapet är att Entra/AD-baserad autentisering ger en mer centraliserad och modern säkerhetsmodell, medan SQL Server Authentication är mer fristående och kompatibel men ofta kräver mer administration.

Azure SQL Database similarly supports two different methods for authentication, SQL Server authentication and Microsoft Entra authentication. SQL Server authentication is the same authentication method that has been supported in SQL Server since it was first introduced, where user credentials are stored within either within the master database, or within the user database.. Authentication via Microsoft Entra ID allows the user to entire the same username and password which is used to access other resources such as the Azure portal or Microsoft 365.

What's the difference between Active Directory and Microsoft Entra ID?

	Active Directory Domain Services	Microsoft Entra ID
User Management	Yes	Yes
Authentication	NTLM and Kerberos	OpenID Connect, SAML, OAuth
Groups	Yes	Yes
Object Hierarchy	Yes	No
Service Principals	Yes	Yes
Query AD programmatically	LDAP	AD Graph API (REST API)

© Copyright Microsoft Corporation. All rights reserved.

Bilden jämför **Active Directory Domain Services (AD DS)** med **Microsoft Entra ID** och visar att båda är katalogtjänster – men byggda för olika världar. AD DS är den klassiska, lokala (on-prem) katalogtjänsten som traditionellt används i Windows-domäner. Microsoft Entra ID (tidigare Azure AD) är istället en molnbaserad identitetsplattform för moderna applikationer och tjänster.

I tabellen ser man att båda stödjer **användarhantering, grupper** och **service principals** (konton för applikationer/tjänster). Den stora skillnaden ligger i autentisering och struktur. AD DS använder främst **NTLM och Kerberos**, vilket passar för Windows-inloggning och domänmiljöer. Entra ID använder moderna protokoll som **OpenID Connect, SAML och OAuth**, vilket är standard för molnappar, API:er och Single Sign-On.

En annan viktig skillnad är **objekthierarki**. AD DS har en tydlig hierarkisk struktur med domäner, OU:er och GPO:er, medan Entra ID inte bygger på samma hierarkiska modell. Slutligen skiljer sig även hur man frågar katalogen programmässigt: AD DS använder **LDAP**, medan Entra ID nås via **Graph/REST-API**.

Sammanfattningsvis: AD DS är domän- och nätverkscentrerat, Entra ID är moln- och appcentrerat.

A common question is what is the difference between Microsoft Entra ID and Windows Server Active Directory. This is especially confusing for new admins, because Microsoft Entra ID interacts with Active Directory. Both solutions provide authentication services and identity management, but in different ways—Active Directory uses a protocol called Kerberos to provide authentication using tickets, and it is queried by the Lightweight Directory Access Protocol (LDAP). Microsoft Entra ID uses HTTPS protocols for authentication like SAML and OpenID Connect for authentication and uses OAuth for authorization.

The two services have different use cases—for example, you cannot join a Windows Server to an Microsoft Entra ID domain and work together in most organizations to provide a single set of user identities. A service called Microsoft Entra Connect, connects your Active Directory identities with your Microsoft Entra ID.

Authentication and identities



Authentication is the process of proving a user or service is who they say there are



Authorization is a process that occurs after a user is authenticated, and grants them their specified access to resources

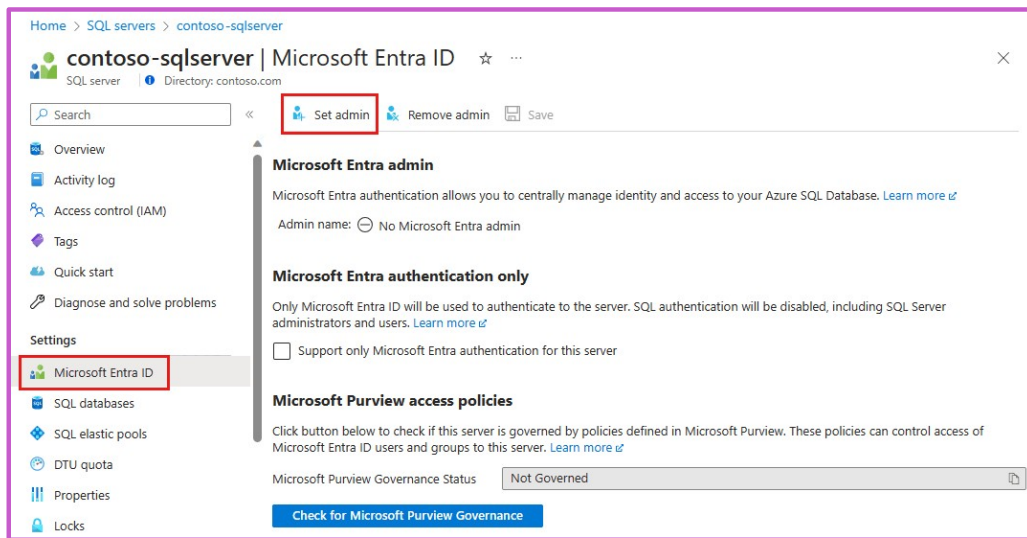


Identities can represent users, service principals, or computers

© Copyright Microsoft Corporation. All rights reserved.

Both on-premises SQL Server installations as well as SQL Server installations within Azure Virtual Machines support two modes of authentication: SQL Server authentication and Windows Authentication. When using SQL Server authentication, SQL Server-specific login name and password information is stored within SQL Server, either in the master database, or in the case of contained users, within the user database. Using Windows Authentication, users to connect to the SQL Server using the same Active Directory account they use to log into their computer (as well as accessing file shares and applications.)

Microsoft Entra admin configuration



© Copyright Microsoft Corporation. All rights reserved.

Microsoft Entra authentication allows integrated authentication into cloud native databases – like Windows Authentication in traditional deployment of SQL Server. Multi-factor authentication is fully supported.

To add users with Microsoft Entra authentication, you must first configure the Microsoft Entra admin.

<https://learn.microsoft.com/en-us/azure/azure-sql/database/authentication-aad-configure>

Demo: Configure Azure AD admin

Configure Microsoft Entra admin for an Azure SQL Database

© Copyright Microsoft Corporation. All rights reserved.

Create a group in Microsoft Entra ID and yourself and another user to it, and then navigate to the Azure SQL server and configure the Azure AD admin to that group. Then login to the Azure SQL DB either using the Query Editor in the portal or SQL Server Management Studio or Azure Data Studio.

--Använd

Microsoft Entra Password

du skriver in användarnamn + lösenord

Bra om Integrated inte fungerar.

SQL Server Security overview

Securables

Object to which access must be secured

Principals

Security identities (users, service principals, or computers) that access securables to perform actions

Permissions

Actions principals can perform on securables

Security Hierarchies

Securables can contain other securables, and principals can contain other principals (roles)

© Copyright Microsoft Corporation. All rights reserved.

What Are Principals?

- Windows On-Prem Principals:
 - Domain user account
 - Local user account
 - Windows group
- Microsoft Entra principals:
 - Users
 - Groups
- SQL Server Principals:
 - SQL Server login (an individual account in the master database/users)
 - Server role
- Database Principals:
 - User
 - Database role
 - Application role

Security principals

Any login, user, group, or role within the server or database

Users within the databases are either mapped to a login, or contained users within the database

Contained users can be based on SQL Authentication or Microsoft Entra ID

Users can then be mapped to roles to give users centrally managed rights, or rights can be granted directly to a user

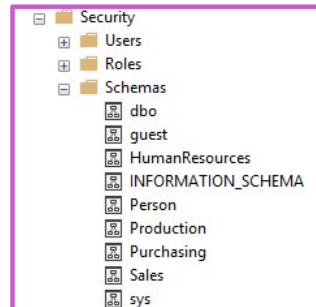
© Copyright Microsoft Corporation. All rights reserved.

Securables and schemas

Securables are resources within databases like tables, views, procedures that access is granted to.

<server>.<database>.<schema>.<object>

A schema is a collection of objects which allows objects to be grouped into separate namespaces.



© Copyright Microsoft Corporation. All rights reserved.

Securables in Azure SQL Database only have the database and schema scopes.

Logins and users

- ✓ Logins are created in the **master** database and are used for server access
- ✓ Instance level permissions are applied to logins
- ✓ Database level permissions are applied to users
- ✓ Contained users are authenticated at the database
- ✓ A user has access only to the database in which they are created

© Copyright Microsoft Corporation. All rights reserved.

No matter the mode of authentication that is used, a login name used to access your SQL database is setup as a login within the instance. Those logins are setup at the instance level of SQL Server and stored in the master database. However, you can configure contained users which are added at the database level. These users can be configured as SQL Server Authentication users as well as either Windows Authentication users or Microsoft Entra users (depending on which platform you are using). In order to create these users, the database must be configured for partial containment, which is configured by default in Azure SQL Database, and optionally configurable in SQL Server.

If logins are created at the instance level in SQL Server, a user should then be created within the user database to map the user to the server-based login

```
USE Master
GO
CREATE LOGIN demo WITH PASSWORD = 'Pa55.w.rd' --server level
GO
USE WideWorldImporters
GO
CREATE USER demo FROM LOGIN demo --database level
GO
```

The user is an Microsoft Entra user as indicated with the FROM EXTERNAL PROVIDER syntax.

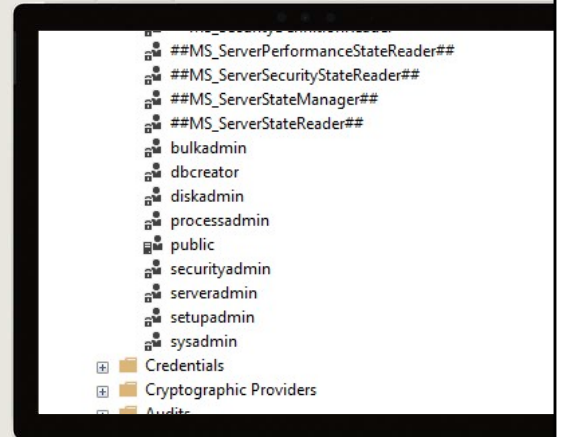
```
CREATE USER [dba@contoso.com] FROM EXTERNAL PROVIDER; GO
```

Built-in roles

Users may be added as members of one or more server/database roles

Server roles cannot be granted access to objects within a database directly and are only available in SQL Server and Azure SQL Managed Instance, but not in Azure SQL Database

The *master* database in Azure SQL Database has a couple of unique roles since the *sysadmin* role doesn't exist



© Copyright Microsoft Corporation. All rights reserved.

[Server-Level Roles - SQL Server | Microsoft Docs](https://learn.microsoft.com/sql/relational-databases/security/authentication-access/server-level-roles): <https://learn.microsoft.com/sql/relational-databases/security/authentication-access/server-level-roles>

Bulkadmin: Can run the BULK INSERT T-SQL statement

Dbcreator: Can create, restore, alter, and drop any database

Diskadmin: Can manage backup devices in SQL Server

Processadmin: Can kill processes running inside of SQL Server

Public: Every SQL Server login belongs to the public user role. Unlike the other fixed server roles, permissions can be granted, denied, or revoked from the public role

Securityadmin: Can manage logins and their properties (for example, changing the password of a login). This role should be treated as being equivalent to the sysadmin role

Serveradmin: Can change server-wide configuration settings (for example Max Server Memory) and can shutdown the server

Setupadmin: Can add and remove linked servers using T-SQL

Sysadmin: Can perform any activity on the server

In addition to database roles, SQL Server and Azure SQL Managed Instance both provide several fixed server roles. These roles assign permissions at the scope of the entire server. Server level principals, which include SQL Server logins, Windows accounts, and Windows group can be added into fixed server roles. The

permissions for fixed server roles are predefined, and no new server roles can be added. The fixed server roles are:

Database roles in SQL Server vs. Azure SQL Database



Roles are used to simplify the process of managing privileges in the database



In SQL Server and Managed Instance the scope of the role may be the **database** or the **server**



In Azure SQL Database roles are scoped to the individual **database**

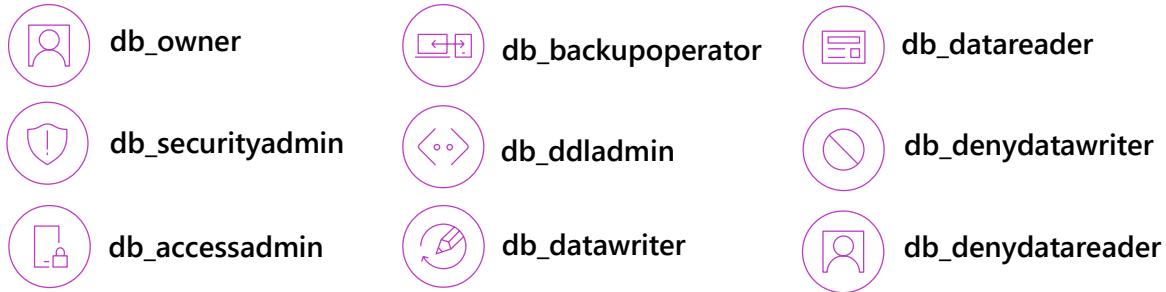


Both SQL Server and Azure SQL Database include built-in **database roles**, and allow for the creation of custom roles

© Copyright Microsoft Corporation. All rights reserved.

As you can imagine, database security can get quite complicated for applications with many users and trying to manage permissions on a per user level. In order to make this easier for both administrators and auditors, most database applications use role-based security. Roles are effectively security groups that share a common set of permissions. This allows a set of roles to be created for a given application. Some examples of roles would be administrators who had full access to all of the databases and servers, reporting users who only read the database, and an application account that had access to write data into the database. The roles can be defined when the application is designed, and then users can be assigned to those roles as they need access to the database. Role based access control or RBAC is a common architecture across computer systems and is how authorization is managed in Azure Resource Manager. SQL Server and Azure SQL Database both include built-in roles that are defined by Microsoft, and the option to create custom roles. Custom roles can be created at the server or database level, however server roles cannot be granted access to objects within a database directly. Server roles are only available in SQL Server and Azure SQL Managed Instance.

Built-in Database Roles



Special roles for Azure SQL Database



© Copyright Microsoft Corporation. All rights reserved.

db_owner

Can perform all configuration and maintenance activities on the database, and can also drop the database in SQL Server. (In SQL Database and Azure Synapse, some maintenance activities require server-level permissions and cannot be performed by db_owners.)

db_securityadmin

Can modify role membership for custom roles only and manage permissions. Members of this role can potentially elevate their privileges and their actions should be monitored.

db_accessadmin

Can add or remove access to the database for Windows logins, Windows groups, and SQL Server logins.

db_backupoperator

Can back up the database.

db_ddladmin

Can run any Data Definition Language (DDL) command in a database.

db_datawriter

Can add, delete, or change data in all user tables.

db_datareader

Can read all data from all user tables.

db_denydatawriter

Cannot add, modify, or delete any data in the user tables within a database.

db_denydatareader

Cannot read any data in the user tables within a database.

Special roles for Azure SQL Database: These database roles exist only in the virtual master database. Their permissions are restricted to actions performed in master. Only database users in master can be added to these roles.

dbmanager – create and delete databases. Like **dbcreator** fixed server role.

loginmanager – create and delete logins in the virtual *master* database. Like **securityadmin** fixed server role.

Database and object permissions explained



DML permissions on tables and views – [SELECT/INSERT/UPDATE/DELETE](#)



Stored procedures and functions have their own permissions –
[ALTER/CONTROL/EXECUTE/VIEW DEFINITION](#)



DCL permissions – [GRANT / DENY / REVOKE](#)
DDL permissions – [CREATE / ALTER / DROP](#)



Revoked permissions remove any existing [GRANT](#) or [DENY](#) permission from the object

© Copyright Microsoft Corporation. All rights reserved.

[Permissions \(Database Engine\) - SQL Server | Microsoft Docs](#): <https://learn.microsoft.com/sql/relational-databases/security/permissions-database-engine>

Right click Database to properties to permissions

Right click a Table to properties to permissions

Tables and views represent the objects where permissions can be granted within a database. Within those tables and views, you can additionally restrict the columns that are accessible to a given security principal (user or login). SQL Server and Azure SQL Database also include row-level security which can be used to further restrict access.

The SELECT permission when granted will allow the user to view the data within the object (table or view). When denied the user will be prevented from viewing the data within the object.

The INSERT permission when granted will allow the user to insert data within the object. When denied the user will be prevented from inserting data into the object.

The UPDATE permission when granted will allow the user the update data within the object. When denied the user will be prevented from updating data in the object.

The DELETE permission when granted will allow the user to delete data within the object. When denied the user will be prevented from deleting data from the object.

Azure SQL Database and Microsoft SQL Server have additional permissions which can be granted, revoked or denied as needed.

The CONTROL permission grants all rights to the objects. This allows the user who has this permission to perform any action they wish against the object, including deleting the object.

The REFERENCES permission grants the user the ability to view the foreign keys on the object.

The TAKE OWNERSHIP permission allows the user the ability to take ownership of the object.

The VIEW CHANGE TRACKING permission allows the user the ability to view the change tracking setting for the object.

The VIEW DEFINITION permission allows the user the ability to view the definition of the object.

Like tables and views, functions and stored procedures there are a variety of permissions which can be granted or denied.

The ALTER permission grants the user the ability to change the schema of the object.

The CONTROL permission grants the user the ability to have all rights to the object.

The EXECUTE permission grants the user the ability to execute the object.

Database and object permissions explained



Permissions can be assigned to users or roles within a database



Permissions are additive, with permissions from multiple role memberships applied together



Preventing access through a **DENY** will override any **GRANT** to that object

© Copyright Microsoft Corporation. All rights reserved.

GRANT/DENY example

```
GRANT SELECT ON dbo.Company to Demo
GO
DENY SELECT ON dbo.Company to Demo
GO
EXECUTE AS USER = 'Demo'
SELECT Name, Address FROM dbo.Company
```

Messages

Msg 229, Level 14, State 5, Line 17
The SELECT permission was denied on the object 'Company', database 'WideWorldImporters', schema 'dbo'.

Completion time: 2020-05-13T14:42:28.8361616-07:00

© Copyright Microsoft Corporation. All rights reserved.

EXECUTE AS USER/EXECUTE AS LOGIN definition



EXECUTE AS USER and **EXECUTE AS LOGIN** allows a statement to be executed in the security context of another user or login



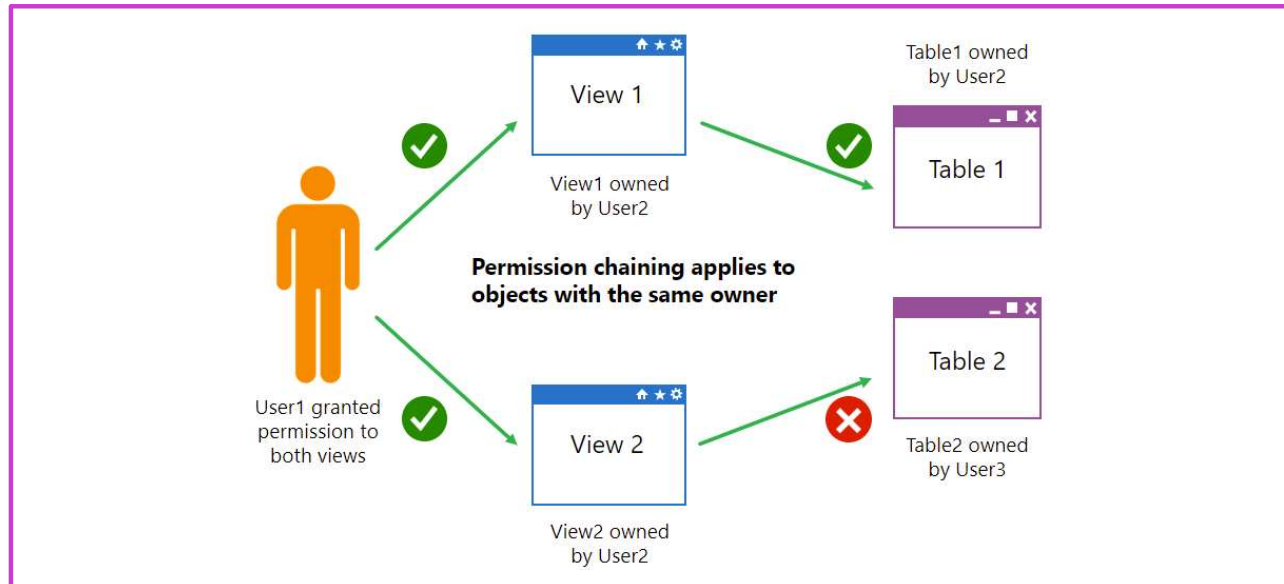
This capability allows for **testing** during the development process to ensure permissions are correctly implemented

© Copyright Microsoft Corporation. All rights reserved.

The EXECUTE AS [user], or EXECUTE AS [login] (only available in SQL Server and Azure SQL Managed Instance) commands allow for the user context to be changed. As subsequent commands and statements will be executed using the new context with the permissions granted to that context.

If a user has a permission and the user no longer needs to have that permission, permissions can be removed (either grants or denies) using the REVOKE command. The revoke command will remove any GRANT or DENY permissions for the right specified to the user specified.

Ownership chains



© Copyright Microsoft Corporation. All rights reserved.

Explain to students how ownership chains affect stored procedures and views. Mention that it also applies to functions.

Use the graphic on the slide to explain that, with an unbroken ownership chain, User1 only needs permission to access the view. In the upper part of the graphic, because the owner of the view and table are the same user, no further permissions are required. In the lower part of the graphic, the view and table have different owners, so User1 needs explicit permissions on both the view and the table.

Demo: Permission chaining

Execute a stored procedure as a lower privileged user

© Copyright Microsoft Corporation. All rights reserved.

Note: This demo is written to be run in the AdventureWorksLT sample database, either in Azure SQL Database or SQL Server. However, if you run it on SQL Server ensure that containment is set ON the database as the users are contained.

Walk through configuring the following T-SQL

```
CREATE USER [DP300User1] WITH PASSWORD = 'Pa55.w.rd'
GO
CREATE ROLE [SalesReader]
GO
ALTER ROLE [SalesReader] ADD MEMBER [DP300User1]
GO
GRANT SELECT, EXECUTE ON SCHEMA::SalesLT TO [SalesReader]
GO

CREATE OR ALTER PROCEDURE SalesLT.DemoProc
as
SELECT P.Name, Sum(SOD.LineTotal) as TotalSales, SOH.OrderDate
FROM SalesLT.Product P
INNER JOIN SalesLT.SalesOrderDetail SOD on SOD.ProductID = P.ProductID
INNER JOIN SalesLT.SalesOrderHeader SOH on SOH.SalesOrderID = SOD.SalesOrderID
GROUP BY P.Name, SOH.OrderDate
ORDER BY TotalSales DESC
GO

EXECUTE AS USER = 'DP300User1'
```

```
SELECT P.Name, Sum(SOD.LineTotal) as TotalSales, SOH.OrderDate
FROM SalesLT.Product P
INNER JOIN SalesLT.SalesOrderDetail SOD on SOD.ProductID = P.ProductID
INNER JOIN SalesLT.SalesOrderHeader SOH on SOH.SalesOrderID = SOD.SalesOrderID
GROUP BY P.Name, SOH.OrderDate
ORDER BY TotalSales DESC
--
```

Dynamic SQL

- Dynamic SQL is a concept where queries are built programmatically and then executed in-line.
- The sample on the right would generate statements to back up each database on a server.

```
SELECT 'BACKUP DATABASE ' +
name + ' TO DISK
= '\\backup\sql1\' + name +
'.bak'''
FROM sys.databases
```

© Copyright Microsoft Corporation. All rights reserved.

```
DECLARE @TableName sysname = N'Customers';
DECLARE @MinId int = 10;
```

```
DECLARE @sql nvarchar(max);
```

```
SET @sql = N'
SELECT *
FROM dbo.' + QUOTENAME(@TableName) + N'
WHERE CustomerId >= @MinId;
';
```

```
EXEC sp_executesql
    @sql,
    N'@MinId int',
    @MinId = @MinId;
```

Dynamic SQL is a concept where a query is built programmatically. This allows T-SQL statements to be generated within a stored procedure or a query itself. A very simple example is shown below.

The above statement will generate a list of T-SQL statements to backup all of the database on the server. Typically, this generated T-SQL will be executed using `sp_executesql` or passed to another program to execute.

Least privilege



The concept of “Least Privilege” means that users never have more permissions than they need to get the task done



If the user runs an application and the user only needs to use stored procedures, then the user should only have the EXECUTE permission for the stored procedure

© Copyright Microsoft Corporation. All rights reserved.

The concept of least privilege is fairly simple. The basic idea behind the concept is that users and applications should only be given the permissions needed in order for them to perform the actions needed to complete the task. This means that applications should only have permissions that they need to do in order to complete the task at hand.

As an example, if an application accesses all data through stored procedures, then the application should only have the permission to execute the stored procedures, with no access to the underlying tables

Identify authentication and authorization failures

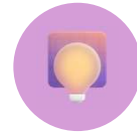
Error	Action
Login failures	Look for any outages during the time when the application reported the errors at Microsoft Azure Service Dashboard.
Database reaches resource limits	Monitor your database's compute and storage resources carefully, and take action when it reaches its resource limits to prevent transient failures.
Extended authentication failures	File an Azure support request through the Azure portal if your application encounters connectivity error for longer than 60 seconds or if it occurs more than once in a given day.

© Copyright Microsoft Corporation. All rights reserved.

A connection failure can result from reconfiguration, firewall settings, connection timeouts, or incorrect login information. Furthermore, if some Azure SQL Database or SQL Managed Instance resources are over capacity, you will not be able to connect.

To learn more about connectivity errors for Azure SQL Database and Azure SQL Managed Instance, see [Troubleshooting connectivity issues and other errors with Azure SQL Database and Azure SQL Managed Instance](#).

Knowledge check



Which protocol is used by Microsoft Entra ID for Authorization?

- ☐ Kerberos
- ☐ LDAP
- ☒ OAuth



What feature allows a user to execute a stored procedure even if she does not have permission to access the tables referenced in the stored procedure?

- ☒ Ownership Chaining
- ☐ Principal of Least Privilege
- ☐ Granular Security



Which role allows users to create users within a database?

- ☐ db_datareader
- ☒ db_accessadmin
- ☐ db_securityadmin

© Copyright Microsoft Corporation. All rights reserved.

1) Which protocol is used by Microsoft Entra ID for Authorization?

☒ **Korrekt: OAuth**

OAuth används för delegerad åtkomst och tokenbaserad auktorisering.

☒ **Felaktigt: Kerberos**

Kerberos används främst i AD DS för Windows-domäner.

☒ **Felaktigt: LDAP**

LDAP är ett katalogprotokoll, inte ett auktoriseringsprotokoll.

2) What feature allows a user to execute a stored procedure...?

☒ **Korrekt: Ownership Chaining**

Ownership chaining låter procedurer använda ägarens behörigheter på objekt.

☒ **Felaktigt: Principle of Least Privilege**

Least privilege är en säkerhetsprincip, inte en SQL-funktion.

☒ **Felaktigt: Granular Security**

Granular security är ett begrepp, inte en specifik mekanism.

3) Which role allows users to create users within a database?

☒ **Korrekt: db_accessadmin**

db_accessadmin kan lägga till och ta bort användare i databasen.

☒ **Felaktigt: db_datareader**

db_datareader ger bara SELECT-rättigheter, inte användarhantering.

☒ **Felaktigt: db_securityadmin**

db_securityadmin hanterar behörigheter, inte själva användarskapandet.

Instructor led labs: Authorize access to Azure SQL Database with Microsoft Entra ID

**Authorize access to Azure SQL Database with Microsoft Entra
Manage access to database objects**

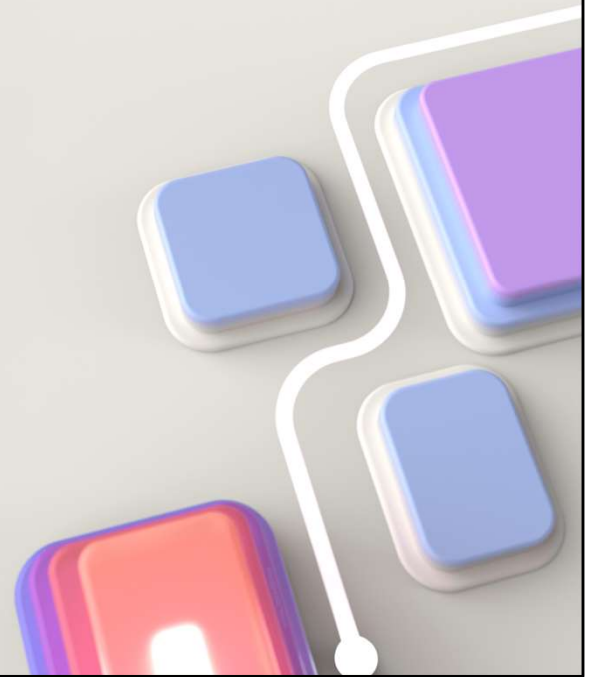
© Copyright Microsoft Corporation. All rights reserved.

<https://microsoftlearning.github.io/dp-300-database-administrator/Instructions/Labs/03-authorize-access-azure-sql-database.html>

Protect data in-transit and at rest

<https://learn.microsoft.com/training/modules/protect-data-transit-rest/>

© Copyright Microsoft Corporation. All rights reserved.



This module explores the encryption options available within Azure SQL. Each of the various platforms support different database encryption options. In this lesson students will explore these data encryption options and how to configure them.

Objectives



Explore data encryption options available in the various platforms



Understand how to configure data at rest encryption for Microsoft SQL Server



Learn how to configure SQL Server to use Azure Key Vault



Explore database and instance firewalls in Azure SQL Database



Understand what Dynamic Data Encryption is used for and how to configure it

© Copyright Microsoft Corporation. All rights reserved.

Encryption at rest



Protects data files, transaction log files, and backup files by requiring a certificate to bring them online



SQL Server and Azure SQL Database implement this through a feature called Transparent Data Encryption (TDE)



You can also encrypt your Azure VM disks to provide an additional level of protection beyond TDE for your SQL Servers



Encrypt drives before you write sensitive data

© Copyright Microsoft Corporation. All rights reserved.

Encryption at rest innebär att data skyddas när den ligger lagrad på disk, till exempel i datafiler, transaktionsloggar och säkerhetskopior. Syftet är att hindra obehöriga från att kunna läsa informationen om filer eller diskar kopieras eller stjäls. I SQL Server och Azure SQL Database implementeras detta vanligtvis med **Transparent Data Encryption (TDE)**, som krypterar databasen automatiskt utan att applikationer behöver ändras. För SQL Server som körs på virtuella maskiner i Azure kan man dessutom kryptera **VM-diskar** för ett extra skyddslager utöver TDE. Grundprincipen är att kryptera lagringsmedia innan känslig data skrivs.

It is important to understand exactly what encryption at rest entails. Encryption at rest does not inherently encrypt data within the database. This provides protection against someone restoring a backup to an unsecured server or making a copy of a database and transaction log file and attaching it to another unsecured server. Encryption at rest does not protect data within a database from user access or prevent data exfiltration by a malicious user.

- Data at rest is the data that has been stored on a physical medium. Data is unreadable without the keys and secrets
- **Azure Disk Encryption** uses Windows BitLocker, Linux dm-crypt
- **Azure Storage** (Azure Storage Service Encryption) and Azure SQL Database (**TDE**) encrypt data at rest by default
- Use **Azure Key Vault** to maintain control of keys

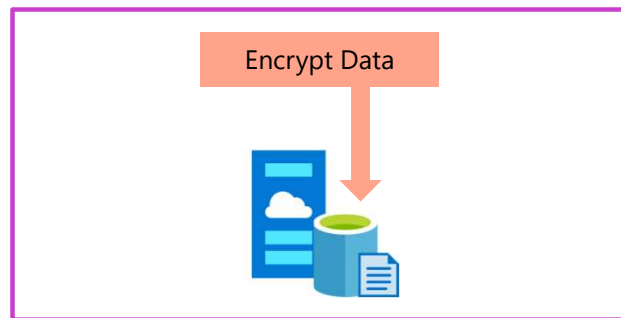
When thinking about data encryption, you should mainly consider three scenarios:

- Encrypting your data at rest, which means encrypting it while it's stored on whatever file storage you use.
- Encrypting your data in transit, which means encrypting data while it travels through private or public network communication channels.
- Encrypting your data in use, which means encrypting it while it's actively used in RAM or CPU caches and registers.

Data at rest vs. Data in transit

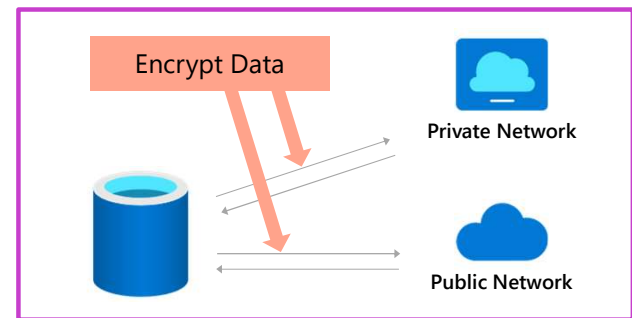
Data at rest

Encrypts data while it's on storage



Data in transit

Encrypts data while it travels through private or public network communication channels



© Copyright Microsoft Corporation. All rights reserved.

Transparent Data Encryption architecture

```
USE master;
GO

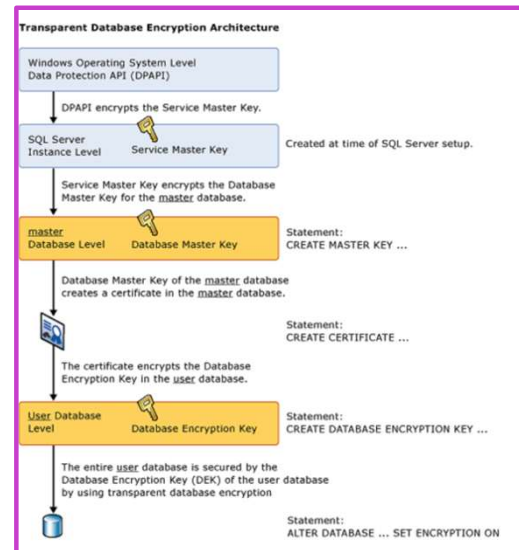
CREATE MASTER KEY ENCRYPTION BY PASSWORD = '<UseStrongPasswordHere>';
GO

CREATE CERTIFICATE MyServerCert
    WITH SUBJECT = 'My DEK Certificate';
GO

USE AdventureWorks2022;
GO

CREATE DATABASE ENCRYPTION KEY
    WITH ALGORITHM = AES_256
    ENCRYPTION BY SERVER CERTIFICATE MyServerCert;
GO

ALTER DATABASE AdventureWorks2022
    SET ENCRYPTION ON;
GO
```



© Copyright Microsoft Corporation. All rights reserved.

[Transparent data encryption](https://learn.microsoft.com/sql/relational-databases/security/encryption/transparent-data-encryption): <https://learn.microsoft.com/sql/relational-databases/security/encryption/transparent-data-encryption>

Transparent Data Encryption (TDE) works by encrypting data in SQL Server and Azure SQL Database on a page level as the page is written to the disk.

- TDE is enabled by **default**
- As data is read from the disk to the buffer pool, it is decrypted before being written to the buffer pool
- Decrypted data is passed to the query processor for joining and returning to the user
- Data is protected as it rests on the disks, and within the backups. Uses symmetric key called the **database encryption key**

Enabling TDE within a Microsoft SQL Server Database is an easy process as only a few T-SQL commands are required. This process involves the following steps:

1. Set a master key within the master database using the `CREATE MASTER KEY ENCRYPTION` command.
2. Create a certificate in the master database, which will be used for the encryption using the `CREATE CERTIFICATE` command.
3. Create a database encryption key within the database, which allows you to enable TDE with the `CREATE DATABASE ENCRYPTION KEY` command.
4. Once the encryption key is created, it needs to be enabled using the `ALTER DATABASE` command.

Managing TDE



Always backup the certificate that is created in the master database



You won't be able to restore this database to the same, or another server without first restoring the certificate



Without a certificate, you won't be able to restore or read the database from backup or attach the data or log files



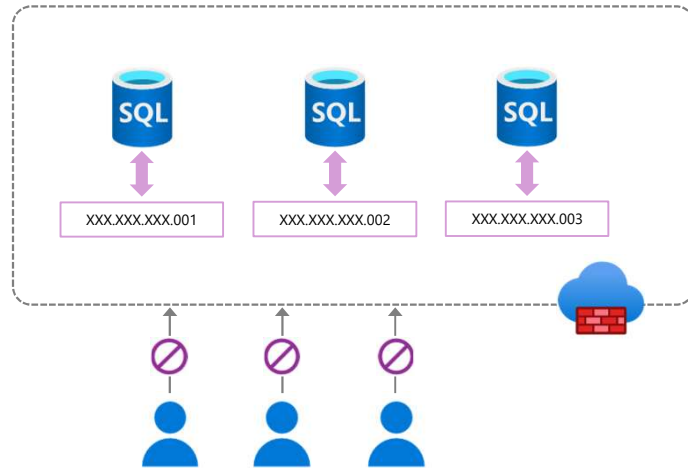
When setting up a database within an Availability Group, restore this certificate to each server within the Availability Group

© Copyright Microsoft Corporation. All rights reserved.

Once the certificate that will be used by TDE has been created, it must be manually backed up and stored in a safe place. SQL Server integrates with Enterprise Key Managers (EKMs) in order to manage encryption keys. An example of an EKM is Azure Key Vault; you can find instructions on integrated SQL Server TDE and Azure Key Vault in the additional resources section of this module. Managing the category is extremely important, because if the certificate is lost and the database backup needs to be restored it will not be able to be restored, as the database cannot be read. To use TDE with databases in an Always On Availability Group, the certificate used to encrypt the database must be backed up and restored to the other servers within the Availability Group which will be hosting copies of the database.

Configure server and database firewall rules

- Each Azure SQL Database has a public IP address hosted by Microsoft. Firewalls prevent unauthorized access to resources.
- By default, block all access and open it as needed.
- Azure SQL Database has firewalls at both the server and database levels.



© Copyright Microsoft Corporation. All rights reserved.

When access through a firewall is opened, anyone at the source IP address has access through to the databases on the Azure SQL server.

Firewall rules should be modified carefully.

Server and database firewall rules

Connection attempts from the internet and Azure must pass through the firewall before they reach your server or database.

Server level

`sp_set_firewall_rule`

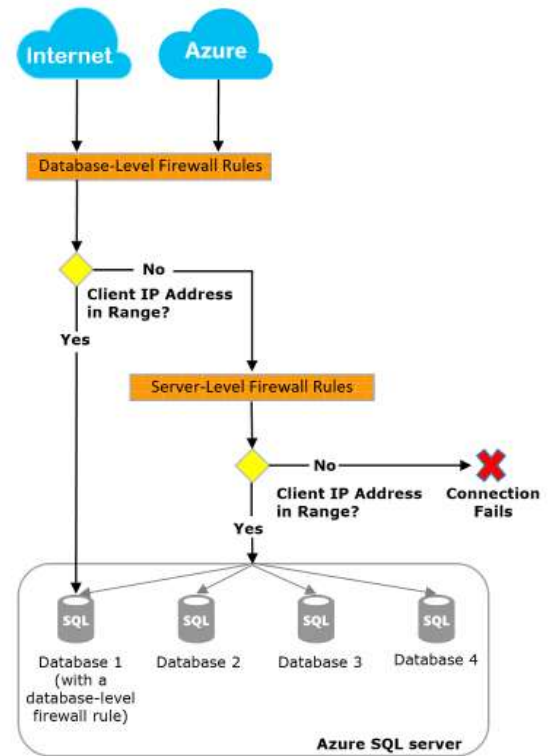
`sp_delete_firewall_rule`

Database level

`sp_set_database_firewall_rule`

`sp_delete_database_firewall_rule`

© Copyright Microsoft Corporation. All rights reserved.



Bilden beskriver hur **brandväggsregler i Azure SQL** fungerar på två nivåer: **servernivå** och **databasnivå**. Alla anslutningsförsök – oavsett om de kommer från internet eller från andra Azure-resurser – måste först passera brandväggen innan de når din Azure SQL-server eller en specifik databas. Principen bygger på att Azure kontrollerar **klientens IP-adress** och jämför den mot tillåtna intervall.

Flödet i diagrammet visar att Azure först kontrollerar om det finns en **databasnivåregel** (database-level firewall rule) som matchar klientens IP. Om IP-adressen ligger inom ett godkänt intervall tillåts anslutningen direkt till just den databasen. Om ingen match finns går kontrollen vidare till **servernivåreglerna** (server-level firewall rules). Om klientens IP inte heller matchar någon serverregel blockeras anslutningen och kopplingen misslyckas.

Servernivåregler gäller för **alla databaser på servern** och kan hanteras via lagrade procedurer som `sp_set_firewall_rule` och `sp_delete_firewall_rule`. Databasnivåregler gäller bara för en enskild databas och hanteras med `sp_set_database_firewall_rule` och `sp_delete_database_firewall_rule`.

Sammanfattningsvis ger servernivån en bred åtkomstkontroll, medan databasnivån möjliggör mer finmaskig säkerhet per databas.

```
EXEC sp_set_database_firewall_rule
    @name = N'AllowMyHomeIP',
    @start_ip_address = '83.250.10.25',
    @end_ip_address = '83.250.10.25';
```

```
SELECT *
FROM sys.database_firewall_rules;
```

Server level firewalls are configured to allow users to connect to the master database and all databases on the instance. Database level firewalls are used to grant or block specific IP Addresses from accessing specific databases.

Server level firewall rules can be configured using the Azure portal or using the *sp_set_database_firewall_rule* stored procedure from within the master database. Database level firewall rules are configured through T-SQL only using the *sp_set_database_firewall_rule* stored procedure from within the user database.

When a computer tries to connect to your server from the internet, the firewall first checks the originating IP address of the request against the database-level IP firewall rules for the database that the connection requests.

- If the address is within a range that's specified in the database-level IP firewall rules, the connection is granted to the database that contains the rule.
- If the address isn't within a range in the database-level IP firewall rules, the firewall checks the server-level IP firewall rules. If the address is within a range that's in the server-level IP firewall rules, the connection is granted. Server-level IP firewall rules apply to all databases managed by the server.
- If the address isn't within a range that's in any of the database-level or server-level IP firewall rules, the connection request fails.

Virtual network endpoints

Network peering allows connectivity from within a Virtual Network to Azure PaaS services including Azure SQL Database

Network Endpoint peering is limited to one Azure region

Network Endpoint peering allows only server level connections, not a database one

Requires outbound access to Azure SQL Database Public IP addresses

© Copyright Microsoft Corporation. All rights reserved.

Virtual network endpoints (ofta kallat *service endpoints*) gör att resurser i ett **Azure Virtual Network** kan nå Azure PaaS-tjänster, t.ex. **Azure SQL Database**, via Microsofts backbone-nät istället för via publika internet. Trafiken går fortfarande mot tjänstens **publika endpoint**, men du kan begränsa åtkomsten så att endast trafik från ett visst VNet/subnet accepteras. Lösningen är regional (kopplad till en Azure-region) och används ofta tillsammans med brandväggsregler. Service endpoints innebär alltså att du får en säkrare nätverkswäg, men utan att tjänsten får en privat IP-adress i ditt nät.

Service endpoints använder fortfarande tjänstens publika endpoint men begränsar åtkomst från VNet. Private Link ger istället en privat IP i ditt VNet och kan helt stänga publik åtkomst.

Private link

Private link allows you to connect various Azure services (including Azure SQL DB) to a private endpoint

A private endpoint is a private IP address within a specific virtual network subnet

This allows for you to use network rules to prevent data exfiltration

Can route directly to Azure SQL DB over ExpressRoute or Point to Point VPN without traversing the public internet

© Copyright Microsoft Corporation. All rights reserved.

Private Link ger åtkomst till Azure-tjänster via en **private endpoint**, vilket är en **privat IP-adress i ett subnet i ditt VNet**. Det innebär att din Azure SQL Database kan nås som om den låg inne i ditt privata nätverk. Trafiken går då helt privat via Azure-nätet och kan även rutas via **VPN eller ExpressRoute**, utan att passera publika internet. Eftersom anslutningen sker med privat IP kan du använda vanliga nätverkskontroller (NSG, routing, DNS) och dessutom minska risken för dataexfiltration. Private Link är därför den mest isolerade och "enterprise-säkra" lösningen.

Service endpoints använder fortfarande tjänstens publika endpoint men begränsar åtkomst från VNet. Private Link ger istället en privat IP i ditt VNet och kan helt stänga publik åtkomst.

The Private Link feature allows you connect to Azure SQL Database (and other PaaS offerings) using a private endpoint. Private endpoint allows for a connection to your Azure SQL Database to go entirely over the Azure backbone network and not over the public internet. This feature provides a private IP address on your Virtual Network. Another feature of private link is that it allows for Azure Express Route connections through that circuit. Private link offers several additional benefits include cross-region private connectivity and protection against data leakage by only allowing connections to specific resources.

Object level encryption



While TDE encrypts the data files and the backup files, it does not encrypt the data within tables



SQL Server uses **Always Encrypted** to encrypt table data, so that only the application with the correct column key can decrypt the data



This protects data from being exfiltrated (unauthorized data transfer) by a malicious administrator

© Copyright Microsoft Corporation. All rights reserved.

In addition to supporting encryption at rest through transparent data encryption, SQL Server supports encrypting data within columns using Always Encrypted. Once data is encrypted, the application accessing the database must have the correct certificate in order to view the plain text values of the data."

Always Encrypted benefits

Encrypts data within tables, protects the data:

- As it **rests** on the disk
- As it is **in flight** between the SQL Server and the client

Allows for data within the database to be encrypted without the database engine ever seeing plain text data

Data is encrypted with certificates created by the database, but stored in the application

Even administrators cannot decrypt the encrypted data

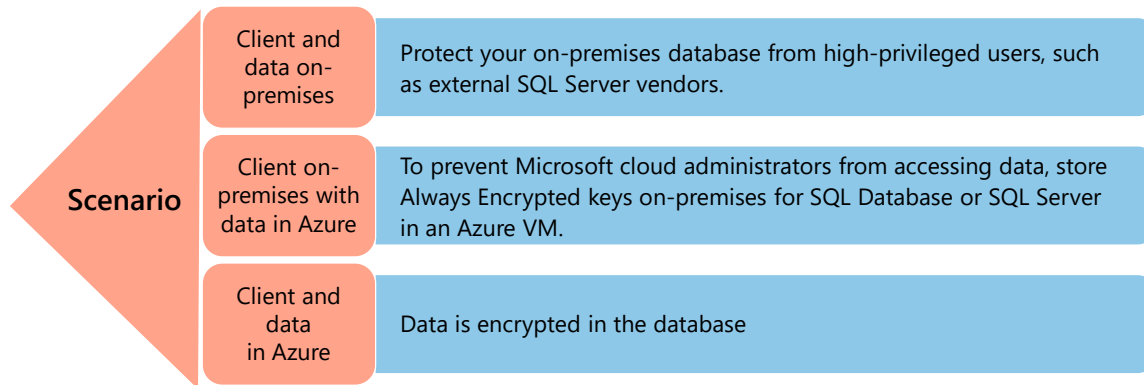
© Copyright Microsoft Corporation. All rights reserved.

There are a variety of ways to encrypt data within the SQL Server tables. This data can be encrypted within the SQL Server using native stored procedures which will encrypt by password or certificate. The data can also be encrypted by the calling application and stored with encrypted values. This includes by using a process called Always Encrypted.

Always Encrypted allows for the encryption of data within the client application driver automatically as needed based on the settings within the Microsoft SQL Server database which tell the application what the encryption settings on the database column are. Always Encrypted is based on a master encryption key as well as a column encryption key. This allows each column to be encrypted using a different encryption key for maximum data protection. Always Encrypted has a variety of key stores which can store the certificate which is used by encryption

Azure SQL Database also supports Always Encrypted.

Always Encrypted encryption types



Deterministic

- Should be used with data that has many distinct values
- **Allows equality joins, grouping and indexing on encrypted columns**

Randomized

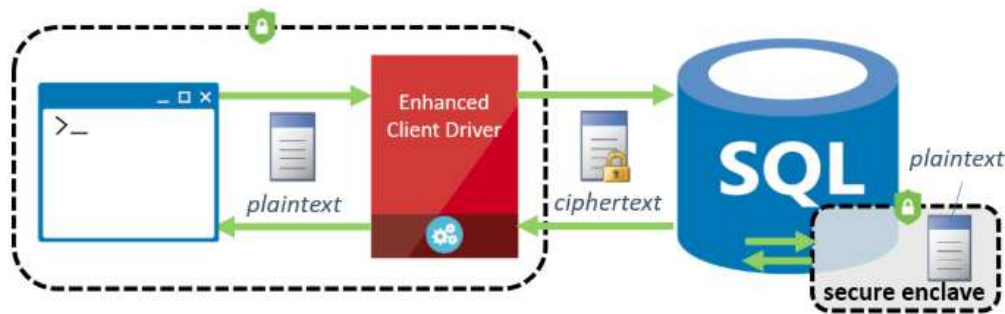
- Most secure. Good for columns with few distinct values
- **Prevents searching, grouping, indexing, joining on encrypted columns and equality operations**

© Copyright Microsoft Corporation. All rights reserved.

What are secure enclaves?

Secure enclaves provide a secure protected area of server memory to decrypt data and perform calculations

Allows for even randomized encrypted data to be compared in queries that do pattern matching or range comparison



© Copyright Microsoft Corporation. All rights reserved.

Bilden förklarar vad **secure enclaves** är och hur de används för att öka säkerheten vid hantering av krypterad data i SQL Server. En secure enclave är ett skyddat område i serverns minne där känslig data tillfälligt kan **dekrypteras och bearbetas**, utan att bli synlig för resten av systemet, operativsystemet eller databasadministratörer.

Diagrammet visar hur en klient skickar data via en *Enhanced Client Driver*. Utanför databasen och i lagring är informationen alltid krypterad (*ciphertext*). När databasen behöver utföra beräkningar, jämförelser eller sökningar – till exempel intervalljämförelser eller LIKE-sökningar – sker detta inne i secure enclaven, där datan tillfälligt finns i klartext (*plaintext*). Resultatet skickas sedan tillbaka i krypterad form.

Poängen är att man kan köra avancerade SQL-frågor på starkt krypterad data utan att kompromissa med säkerheten. Secure enclaves möjliggör därmed både hög datasäkerhet och praktisk användbarhet i moderna databassystem.

Always Encrypted, starting with SQL Server 2019, supports a feature called secure enclaves, which allows more robust querying of data. A secure enclave is a secured region of memory within the SQL Server process which acts as trusted execution environment for processing encrypted data within the SQL Server engine. This enclave appears as black box to SQL Server, and it is not possible to view any data or code, even with a debugger

Demo: Always Encrypted

Encrypting data

© Copyright Microsoft Corporation. All rights reserved.

Create a copy of the *AdventureWorks HumanResources.Employee* table by executing the following T-SQL:

```
SELECT * INTO HumanResources.EmployeeAE FROM HumanResources.Employee
```

(The original table a check constraint that blocks encryption.)

Start by Right Clicking on the Table > Choose Encrypt Columns

It brings up a Wizard, one of the two recommend ways to configure AE. The other option is to use PowerShell.

Click Next on the Intro Screen

You will note in the example below, that it lists the columns and then shows the encryption STATE, which indicates if the column is eligible for encryption. There are several unsupported column characteristics that may make it so a column cannot be encrypted. The items on this list are unsupported because they have a default constraint or a check constraint defined:

In this case, the column we want is *BirthDate*, so I place a check next to it. To continue I need to **Choose a Type of Encryption**. Select deterministic from the drop down and then click next.

If this is a new instance you need to create a master key. By default the wizard will autogenerate a master key. Also, accept the default of Windows certificate store, but mention Azure Key Vault and how it can be used. Click Next. On the next screen, accept the default of Proceed to Finish Now and click next. On the next screen click finish.

Execute the following query:

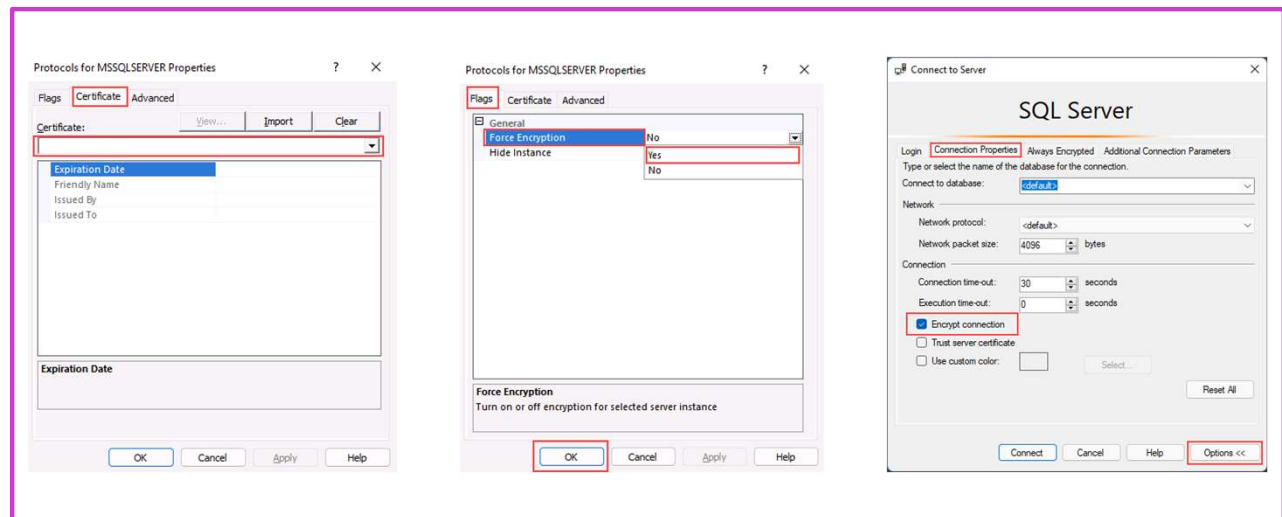
```
SELECT * FROM HumanResources.EmployeeAE
```

Highlight that the *BirthDate* column is encrypted.

Open a new connection to your server, with the option Enable Always Encrypted box check on the Always Encrypted table in the connect to server window. Rerun the query against the encrypted table, you will see a pop up box, click enable. The query results will have unencrypted data.

Ensure you explain to the students that having the certificate on the server is an insecure configuration and for demo purposes only.

Enable encrypted connections on SQL Server



© Copyright Microsoft Corporation. All rights reserved.

You can configure a SQL Server instance to use encrypted connections by following these steps:

1. On the **SQL Server Configuration Manager**, expand **SQL Server Network Configuration**, right-click **Protocols for <server instance>**, and then select **Properties**.
2. From the **Protocols for <server instance> Properties** dialog box, select the **Certificate** tab, then select the certificate from the **Certificate** drop-down.
3. On the **Flags** tab, in the **ForceEncryption** property, select **Yes**, and then click **OK**.
4. Restart the SQL Server service.

Once the necessary configuration is in place, you can test the connection through SQL Server Management Studio:

On the **Connection Properties** tab, click **Encrypt connection**, and then **Connect**.

What is SQL Injection?

- SQL Injection is an attack in which malicious code is inserted into strings that are later passed to a database engine
- SQL Injection is a possibility whenever dynamic SQL is used with user input
- An example is shown here >

© Copyright Microsoft Corporation. All rights reserved.

C#:

```
var shipCity;
shipCity = Request.form ("shipCity");
var sql = "select * from OrdersTable
where shipCity = '" + ShipCity + '"";
```

User Input:

```
Redmond'; drop table OrdersTable-
-
```

Executed SQL:

```
SELECT * FROM OrdersTable WHERE
ShipCity = 'Redmond'; drop table
OrdersTable--'
```

--I övre exemplet visas alla rader, vilket inte är meningen
 DECLARE @LastName NVARCHAR(100) = '' OR 1=1 --';

 -- ❌ FEL: SQL injection (returnerar ALLA kunder)

DECLARE @sql_bad NVARCHAR(MAX);

SET @sql_bad = N'
 SELECT CustomerID, FirstName, LastName
 FROM SalesLT.Customer
 WHERE LastName = ' + @LastName;

PRINT @sql_bad; -- Visa vad som faktiskt körs, alla rader
 EXEC(@sql_bad);
 GO

 -- ✅ RÄTT: Parametriserad sp_executesql

DECLARE @LastName NVARCHAR(100) = '' OR 1=1 --';

DECLARE @sql_good NVARCHAR(MAX);

SET @sql_good = N'
 SELECT CustomerID, FirstName, LastName

```
FROM SalesLT.Customer  
WHERE LastName = @LastName';
```

```
EXEC sp_executesql  
    @sql_good,  
    N'@LastName NVARCHAR(100)',  
    @LastName = @LastName;
```

SQL Injection is one of the most common methods used for data breaches. The core of the attack is that an SQL command is appended to the back end of a form field in the web or application front end (usually through a website), with the intent of breaking the original SQL Script and then executing the SQL script that was injected into the form field. This SQL injection most often happens when you have dynamically generated SQL within your client application. The core reason behind an SQL Injection attack comes down to poor coding practices both within the client application and within the database stored procedures. Many developers have learned better development practices, but SQL Injection is still a big problem due to both the number of legacy applications still being used and newer applications built by developers who didn't take SQL Injection seriously while building the application.

What is Azure Key Vault?



Key Vault is a solution to safeguard cryptographic keys and other secrets



It can be used in conjunction with Azure VMs running SQL Server to store Transparent Data Encryption and Always Encrypted certificates



This can also be used with on-premises servers



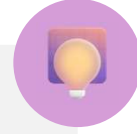
Azure SQL VM resource provider integrates with Key Vaults and can store your TDE certificates in Azure Key Vault

© Copyright Microsoft Corporation. All rights reserved.

Azure Key Vault är en tjänst i Azure som används för att **lagra och skydda hemligheter** som lösenord, certifikat och krypteringsnycklar. Istället för att spara sådana känsliga uppgifter i kod eller konfigurationsfiler kan man lägga dem i Key Vault och ge behörighet till rätt användare och tjänster. Key Vault kan användas tillsammans med SQL Server, till exempel för att lagra certifikat för **Transparent Data Encryption (TDE)** och **Always Encrypted**. Det fungerar både för SQL Server som körs i **Azure VM** och även för vissa lösningar med **on-premises** servrar. Målet är bättre säkerhet och enklare hantering av nycklar.

Azure Key Vault is a tool used for storing and accessing secrets. Whether they be passwords, certificates or keys, Key Vault acts as a secure area for those secrets to be accessed in a secure fashion, typically programmatically. Key Vault data has its own RBAC policies, separate from the Azure subscription. This means someone who is in the role of subscription admin will not have access to the Key Vault unless explicitly granted.

Knowledge check



Which feature provides a private IP address for an Azure SQL Database?

- ☐ Network Endpoints
- ☒ Private Link
- ☐ Database Firewall



Which technique can be used to create database firewall rules in Azure SQL Database?

- ☐ Running a PowerShell script
- ☐ Running an Azure CLI script
- ☒ Executing a T-SQL statement



Which feature prevents members of the sysadmin role from viewing the values of data in a table?

- ☒ Always Encrypted
- ☐ Dynamic Data Masking
- ☐ Transparent Data Encryption

© Copyright Microsoft Corporation. All rights reserved.

1) Which feature provides a private IP address for an Azure SQL Database?

☒ **Rätt: Private Link**

Ger en privat endpoint med privat IP i ditt VNet.

☒ **Fel: Network Endpoints**

Service endpoints använder publik endpoint, ingen privat IP-adress.

☒ **Fel: Database Firewall**

Firewall styr åtkomst, men ger ingen privat IP-adress.

2) Which technique can be used to create database firewall rules?

☒ **Fel: Running a PowerShell script**

PowerShell kan användas, men frågan avser databasnivå via T-SQL.

☒ **Fel: Running an Azure CLI script**

CLI kan sätta serverregler, men databasregler görs med T-SQL.

☒ **Rätt: Executing a T-SQL statement**

Databasnivå brandväggsregler skapas med T-SQL-procedurer.

3) Which feature prevents sysadmin from viewing table data values?

☒ **Rätt: Always Encrypted**

Data förblir krypterad i databasen, även för sysadmin.

☒ **Fel: Dynamic Data Masking**

Maskering kan kringgå av privilegierade användare och admins.

☒ **Fel: Transparent Data Encryption**

TDE skyddar filer på disk, inte data vid SELECT-frågor.

Instructor led labs: Configure Azure SQL Database firewall rules

Configure Azure SQL Database firewall rules
Validate access

© Copyright Microsoft Corporation. All rights reserved.

<https://microsoftlearning.github.io/dp-300-database-administrator/Instructions/Labs/04-configure-firewall-rule.html>

Implement compliance controls for sensitive data

<https://learn.microsoft.com/training/modules/implement-compliance-controls-sensitive-data/>

© Copyright Microsoft Corporation. All rights reserved.

This module explores the practices of setting compliance controls on the data that is stored within the SQL Server database. We will also review the Advanced Threat Protection options within the Azure environment.

Objectives



How data should be classified



Why data classification should be done



How to implement row level security and dynamic data masking



Understand the usage of Microsoft Defender for SQL



How Azure SQL Database Ledger works

© Copyright Microsoft Corporation. All rights reserved.

This module explores the practices of setting compliance controls on the data that is stored within the SQL Server database. We will also review the Advanced Threat Protection options within the Azure environment.

Data classification



Describes how the data must be treated



Create data governance policies that consider data classification. For example:

- Data that is marked as highly confidential shouldn't be included in reports that are distributed to the entire company
- Data subject to GDPR should be included in any requests for data deletion (right to be forgotten)



By classifying data, and setting proper permissions to view data, you can ensure that users should only be seeing the data that they are allowed to see with the database

© Copyright Microsoft Corporation. All rights reserved.

Confidential data stored within a Microsoft SQL Server or Azure SQL Database should be classified within the database. This allows the SQL Server users as well as other applications to know the sensitivity of the data that is being stored. Data classification with the database is done on a column by column basis. It is possible for a single table to have public, confidential and highly confidential data all within the same table. Data classification was introduced first into SQL Server Management Studio and used extended properties of objects to store its data classification information. Starting with SQL Server 2019 (and in Azure SQL Database) this metadata is now stored in a catalog view called *sys.sensitivity_classifications*.

How your data should be classified

- Data within tables is classified on a column-by-column basis
- A single table can have data that is Public, General, Confidential and Highly Confidential
- Azure SQL Database can automatically classify your database based on column names
- You can also manually classify data using SSMS or T-SQL ([ADD SENSITIVITY CLASSIFICATION](#))

© Copyright Microsoft Corporation. All rights reserved.

Add Classification

Data Classification

Schema

HumanResources

Table

Employee

Column

BirthDate

Information Type

Date Of Birth

Sensitivity Label

Confidential - GDPR

Explore server and database audit

- Tracks database events and writes them to an audit log in your Azure Storage account, Log Analytics workspace, or Event Hubs
- You can define **server-level** and **database-level** policies

© Copyright Microsoft Corporation. All rights reserved.

Save Discard View audit logs

Feedback

View server settings

Server-level Auditing: **Enabled**

Azure SQL Auditing

Azure SQL Auditing tracks database events and writes them to an audit log in your Azure Storage account, Log Analytics workspace or Event Hub.

[Learn more about Azure SQL Auditing](#)

Enable Azure SQL Auditing ⓘ On

Audit log destination (choose at least one):

☐ Storage

☐ Log Analytics

☐ Event Hub

Additional Auditing

Use Ledger for auditing and Compliance

Ledger provides cryptographic proof of data integrity to auditors. This proof can help streamline the auditing process.

[Start](#)

It's recommended that you enable only server-level auditing and leave the database-level auditing **disabled** for all databases

Enables you to maintain regulatory compliance, analyze activity patterns, and identify deviations that may indicate security violations.

You can define server-level and database-level policies. Server policies automatically cover new and existing databases in Azure.

- If server auditing is enabled, the database will be audited, regardless of the database auditing settings.
- In addition to enabling auditing on the server, you can also enable it on the database. This allows both audits to exist simultaneously; the server policy and the database policy.

It is best not to enable both server auditing and database auditing together, unless:

- A different *storage account*, *retention period* or *Log Analytics Workspace* is used for a specific database.
- An audit is needed for a specific database that differs from the rest on the server, such as different event types or categories.

For all the other cases, we recommend that you enable only server-level auditing and leave the database-level auditing disabled for all databases.

Explore server and database audit cont'd

Default auditing policy for SQL Database includes:

Action group	Definition
BATCH_COMPLETED_GROUP	Audits all the queries and stored procedures executed against the database.
SUCCESSFUL_DATABASE_AUTHENTICATION_GROUP	This indicates that a principal succeed to log into the database.
FAILED_DATABASE_AUTHENTICATION_GROUP	This indicates that a principal failed to log into the database.

© Copyright Microsoft Corporation. All rights reserved.

Explore server and database audit cont'd

Audit sensitive labels: When combined with data classification, you can also monitor access to sensitive data.

name	action_name	class_type_desc	data_sensitivity_information
audit_event	BATCH COMPLETED	DATABASE	
audit_event	BATCH COMPLETED	DATABASE	
audit_event	BATCH COMPLETED	DATABASE	
audit_event	BATCH COMPLETED	DATABASE	<sensitivity_attributes max_rank="20" max_rank_desc="Medium"><sensitivity_attribute label="Confidential - GDPR" label_id="bf91e08c-f40-478a-b016-25164b2a659f" information_type="Name"
audit_event	BATCH COMPLETED	DATABASE	<sensitivity_attributes max_rank="20" max_rank_desc="Medium"><sensitivity_attribute label="Confidential - GDPR" label_id="bf91e08c-f40-478a-b016-25164b2a659f" information_type="Name"
audit_event	BATCH COMPLETED	DATABASE	<sensitivity_attributes max_rank="20" max_rank_desc="Medium"><sensitivity_attribute label="Confidential - GDPR" label_id="bf91e08c-f40-478a-b016-25164b2a659f" information_type="Name"
audit_event	BATCH COMPLETED	DATABASE	<sensitivity_attributes max_rank="20" max_rank_desc="Medium"><sensitivity_attribute label="Confidential - GDPR" label_id="bf91e08c-f40-478a-b016-25164b2a659f" information_type="SSN"

© Copyright Microsoft Corporation. All rights reserved.

By logging the sensitivity labels of the data returned by a query, this field provides an easier way to track access to classified columns.

Dynamic Data Masking

- Dynamic Data Masking (DDM) is used to prevent users from seeing sensitive data.
- Data can be unmasked by simply granting a right to a user
- Server admins will always have access to unmasked data

```

ALTER TABLE [Application].[People] ALTER COLUMN [PhoneNumber] ADD MASKED WITH (FUNCTION = 'partial(0,"XXX-XXX-",4)')
ALTER TABLE [Application].[People] ALTER COLUMN [EmailAddress] ADD MASKED WITH (FUNCTION = 'email()')

EXECUTE AS USER = 'DDMDemo'

SELECT [PersonID]
      ,[FullName]
      ,[PhoneNumber]
      ,[EmailAddress]
FROM [WideWorldImporters].[Application].[People]
WHERE [PhoneNumber] is NOT NULL

```

PersonID	FullName	PhoneNumber	EmailAddress
2	Kayla Woodcock	XXX-XXX-0102	iXXX@XXXX.com
3	Hudson Onslow	XXX-XXX-0102	hXXX@XXXX.com
4	Isabella Rupp	XXX-XXX-0102	iXXX@XXXX.com
5	Eva Muirden	XXX-XXX-0102	eXXX@XXXX.com
6	Sophia Hinton	XXX-XXX-0102	sXXX@XXXX.com
7	Amy Trefl	XXX-XXX-0102	aXXX@XXXX.com
8	Anthony Grosse	XXX-XXX-0102	aXXX@XXXX.com

© Copyright Microsoft Corporation. All rights reserved.

- Dynamic Data Masking hides data from view by using a user defined value instead of the actual data which is stored
- The data is masked server side, meaning unmasked data is never transmitted over the network

Dynamic Data Masking implementation

Data can be masked in different ways with several built-in masks:

Default	Credit card	Social Security number	Random number	Custom text
Full Masking based on data types of the field (no data exposed)	Shows the last four digits of a credit card number	Shows the last 4 digits XXX-XX-1234	Generates random numbers according to the boundaries	Exposes first and last characters and adds custom string in the middle

© Copyright Microsoft Corporation. All rights reserved.

Talk about some of the Dynamic Data Masking use cases:

- Mask data from application users who have no direct access to the database.
- Restricting private information for a group of users.
- Provide masked data to external vendors, where you need to protect sensitive information while still preserving the relationships among items in the data.
- Export a copy of your production database to a lower environment for development purposes with a user who doesn't have UNMASK permission. The export of the data will be in a masked format.

Row level security



Operates at the database level to restrict access to a table by using a security policy – Equivalent to a WHERE clause



Depending on the attribute of a user, the predicate determines if the user has access



- **Filter predicate** – Restrict data access that violate predicate (SELECT, UPDATE, DELETE, INSERT)
- **Block predicate** – Restrict data changes that violate predicate (AFTER INSERT, AFTER UPDATE, BEFORE UPDATE, BEFORE DELETE)

© Copyright Microsoft Corporation. All rights reserved.

Microsoft offers a suite of protections for Azure SQL Database Databases which wrap up under the Advanced Threat Protection feature. Advanced Threat Protection monitors the connections to the Azure SQL Database databases and queries which are executed against the database. To get maximum benefit out of Advanced Threat Detection you will want to enable auditing on your databases. To allow for investigation if Advanced Threat Detection detects an anomaly it is recommend to enable auditing on your databases.

Row level security use cases and best practices

Use cases:

- To isolate departmental access at the row level.
- To restrict customers' data access to only the data relevant to their company.
- To restrict access for compliance purposes.

Best practices:

- Create a separate schema for predicate functions and security policies.
- Avoid type conversions in predicate functions.
- Avoid using excessive table joins and recursion in predicate functions.

© Copyright Microsoft Corporation. All rights reserved.

Microsoft offers a suite of protections for Azure SQL Database Databases which wrap up under the Advanced Threat Protection feature. Advanced Threat Protection monitors the connections to the Azure SQL Database databases and queries which are executed against the database. To get maximum benefit out of Advanced Threat Detection you will want to enable auditing on your databases. To allow for investigation if Advanced Threat Detection detects an anomaly it is recommend to enable auditing on your databases.

Microsoft Defender for SQL



Offers a suite of protections for Azure SQL Database and Azure SQL Managed Instance as part of the advanced SQL security features



Advanced Threat Protection watches for:

- Suspicious database activities
- Potential database vulnerabilities
- SQL Injection Attacks
- Anomalous database access and query patterns



SQL vulnerability assessment is a service that uses a knowledge base of security rules to flag items that do not comply when they are scanned.

© Copyright Microsoft Corporation. All rights reserved.

Microsoft offers a suite of protections for Azure SQL Database Databases which wrap up under the Advanced Threat Protection feature. Advanced Threat Protection monitors the connections to the Azure SQL Database databases and queries which are executed against the database. To get maximum benefit out of Advanced Threat Detection you will want to enable auditing on your databases. To allow for investigation if Advanced Threat Detection detects an anomaly it is recommend to enable auditing on your databases.

Azure SQL Database Ledger



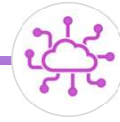
Easy audits

- Cryptographically verifies to auditors and other business parties that your data remains untampered.
- Simplifies compliance reporting by providing clear, verifiable audit trails.



Increased trust

- Maintains a collection of accounts of a specific type, enhancing reliability.
- Strengthens confidence among stakeholders by ensuring consistent and accurate data management.



Data integrity

- Ensures transparent protection against malicious actors, including attackers and even database or cloud administrators.
- Reduces risk of data breaches through robust security measures and continuous monitoring.

© Copyright Microsoft Corporation. All rights reserved.

Bilden beskriver **Azure SQL Database Ledger**, en funktion som används för att säkerställa att data i en Azure SQL-databas inte har manipulerats i efterhand. Överst visas namnet på funktionen tillsammans med en cirkulär symbol som antyder ett kontinuerligt och oföränderligt flöde av information, likt ett bokförings- eller revisionsspår.

Innehållet är uppdelat i tre huvudområden.

Easy audits förklarar att Ledger kryptografiskt kan bevisa för revisorer och andra intressenter att data förblir oförändrad. Detta gör revisioner enklare och ger tydliga, verifierbara spår för efterlevnad av regelverk. I

Increased trust handlar om ökat förtroende: genom att lagra data på ett konsekvent och tillförlitligt sätt stärks tilliten mellan olika parter, exempelvis organisationer, kunder och tillsynsmyndigheter.

Data integrity fokuserar på dataintegritet och skydd mot manipulation, även från privilegierade användare som administratörer. Sammantaget visar bilden hur Azure SQL Database Ledger kombinerar säkerhet, transparens och spårbarhet för att skydda kritisk data.

The ledger feature of Azure SQL Database provides tamper-evidence capabilities in your database. You can cryptographically attest to other parties, such as auditors or other business parties, that your data hasn't been tampered with.

The Azure SQL Database Ledger feature provides multiple benefits:

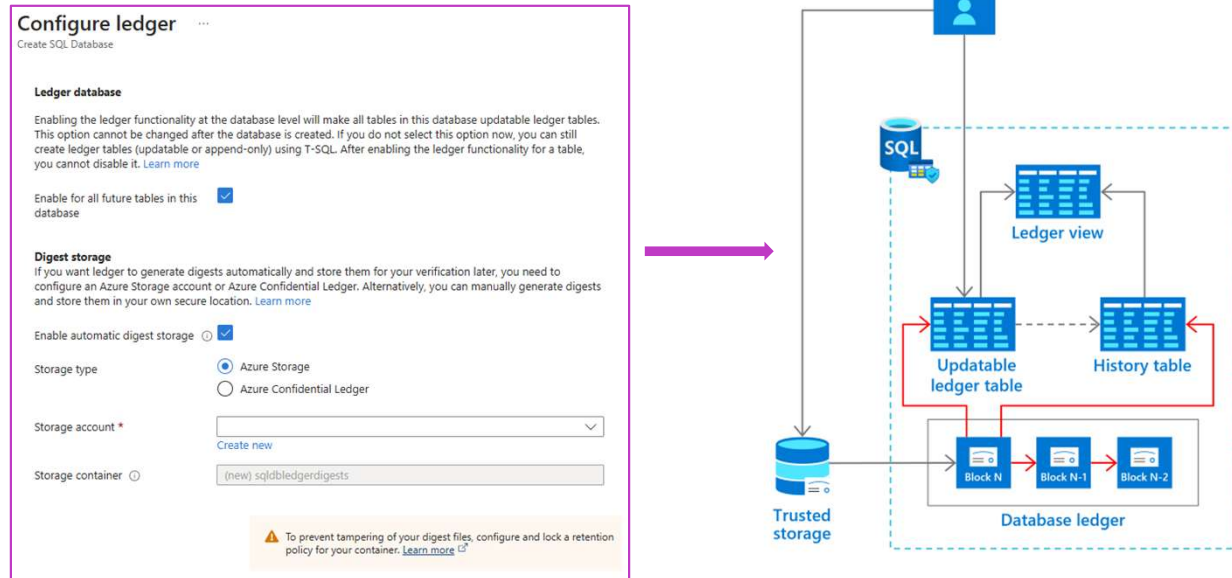
Ease Audits – Audits are frequently enacted to ensure that proper security controls are in place to reduce potential attacks, backup and restore practices are as required, and thorough disaster recovery procedures are in place. Ledger provides documented proof that your data hasn't been altered in an auditing process.

Increased trust – Ledger also can help establish trust between multiple-party business processes

without the complexity and performance implications that network consensus can introduce.

Data integrity – Querying the data on a blockchain network without sacrificing performance can be a serious challenge. Ledger provides data integrity for off-chain storage of blockchain networks, which helps ensure complete data trust through the entire system.

Enable Azure SQL Database Ledger



© Copyright Microsoft Corporation. All rights reserved.

On the Configure ledger pane, in the Ledger section, the **Enable for all future tables in this database** checkbox ensures that all future tables in the database will be ledger tables. For this reason, all data in the database will show any evidence of tampering. By default, new tables will be created as updatable ledger tables, even if you don't specify `LEDGER = ON` in the `CREATE TABLE` statement.

In the **Digest Storage** section, **Enable automatic digest storage** is automatically selected. Then, a new Azure Storage account and container where your digests are stored is created.

Microsoft Purview

Unified data governance service to manage and govern on-premises, multi-cloud, and software-as-a-service (SaaS) data

Make data easy to find using familiar business and technical search terms

Get key insights to add or redistribute glossary terms for better search results

View your entire data domain and its distribution by asset dimension, such as source type, classification, and file size

© Copyright Microsoft Corporation. All rights reserved.

Bilden beskriver **Microsoft Purview**, en plattform för enhetlig **data governance**, alltså styrning och kontroll av data i en organisation. Överst framgår att Purview är utformat för att hantera data oavsett var den finns: lokalt (on-premises), i flera moln (multi-cloud) eller i olika SaaS-tjänster. Tanken är att samla all datastyrning i en och samma lösning.

Under rubriken listas tre centrala funktioner.

Den första handlar om att göra data **lätt att hitta**, genom att använda både affärstermer och tekniska begrepp som användare redan är bekanta med.

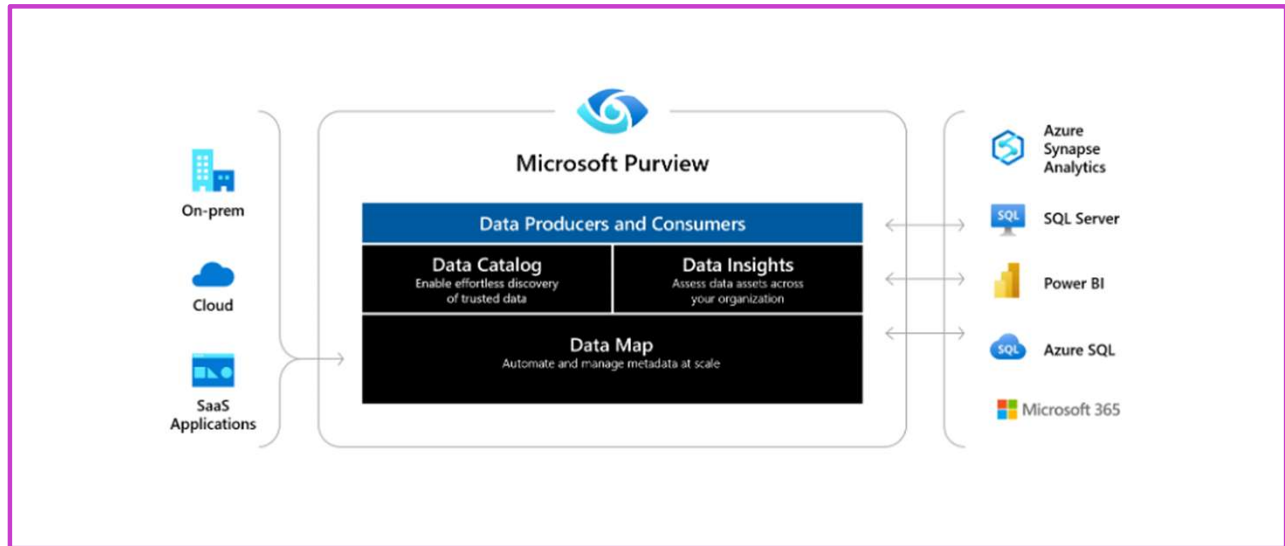
Den andra funktionen fokuserar på **insikter kring begreppslistor (glossary)**, där man kan förbättra sökbarheten genom att lägga till eller omfördela termer baserat på hur datan används.

Den tredje funktionen ger en **helhetsvy över hela datadomänen**, där data kan analyseras och grupperas efter exempelvis källtyp, klassificering och filstorlek. Sammantaget visar bilden hur Microsoft Purview hjälper organisationer att få kontroll, överblick och bättre förståelse för sin data.

Microsoft Purview is a unified data governance service that helps you manage and govern your on-premises, multi-cloud, and software-as-a-service (SaaS) data. Create a holistic, up-to-date map of your data landscape with automated data discovery, sensitive data classification, and end-to-end data lineage. Enable data curators to manage and secure your data estate. Empower data consumers to find valuable, trustworthy data.

Microsoft Purview automates data discovery by providing data scanning and classification as a service for assets across your data estate. Metadata and descriptions of discovered data assets are integrated into a holistic map of your data estate. Atop this map, there are purpose-built apps that create environments for data discovery, access management, and insights about your data landscape.

Microsoft Purview



© Copyright Microsoft Corporation. All rights reserved.

Bilden visar hur **Microsoft Purview** fungerar som en central plattform för datastyrning. Den kopplar samman data från lokala system, molnet och SaaS-applikationer. Purview erbjuder en datakatalog, datainsikter och en datakarta som stödjer både dataskapare och användare i organisationen.

Microsoft Purview is a unified data governance service that helps you manage and govern your on-premises, multi-cloud, and software-as-a-service (SaaS) data. Create a holistic, up-to-date map of your data landscape with automated data discovery, sensitive data classification, and end-to-end data lineage. Enable data curators to manage and secure your data estate. Empower data consumers to find valuable, trustworthy data.

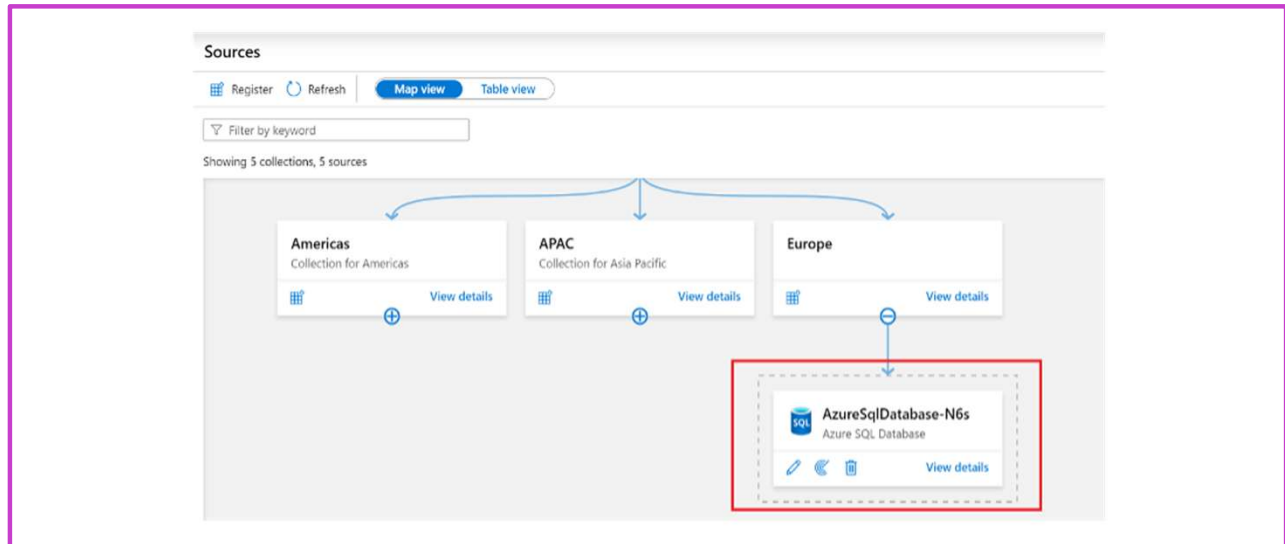
Microsoft Purview automates data discovery by providing data scanning and classification as a service for assets across your data estate. Metadata and descriptions of discovered data assets are integrated into a holistic map of your data estate. Atop this map, there are purpose-built apps that create environments for data discovery, access management, and insights about your data landscape.

[Data Map](#) - Makes your data meaningful by graphing your data assets, and their relationships, across your data estate. The data map used to discover data and manage access to that data.

[Data Catalog](#) - Finds trusted data sources by browsing and searching your data assets. The data catalog aligns your assets with friendly business terms and data classification to identify data sources.

[Data Estate Insights](#) - Gives you an overview of your data estate to help you discover what kinds of data you have and where.

Microsoft Purview



© Copyright Microsoft Corporation. All rights reserved.

Bilden visar **Microsoft Purview Map View**, där datakällor organiseras hierarkiskt i samlingar, till exempel efter regioner som Americas, APAC och Europe. Under varje samling visas anslutna datakällor, här illustrerat med en Azure SQL Database. Vyn ger en tydlig överblick över hur data är strukturerad och förvaltat.

Microsoft Purview is a unified data governance service that helps you manage and govern your on-premises, multi-cloud, and software-as-a-service (SaaS) data. Create a holistic, up-to-date map of your data landscape with automated data discovery, sensitive data classification, and end-to-end data lineage. Enable data curators to manage and secure your data estate. Empower data consumers to find valuable, trustworthy data.

Microsoft Purview automates data discovery by providing data scanning and classification as a service for assets across your data estate. Metadata and descriptions of discovered data assets are integrated into a holistic map of your data estate. Atop this map, there are purpose-built apps that create environments for data discovery, access management, and insights about your data landscape.

[Data Map](#) - Makes your data meaningful by graphing your data assets, and their relationships, across your data estate. The data map used to discover data and manage access to that data.

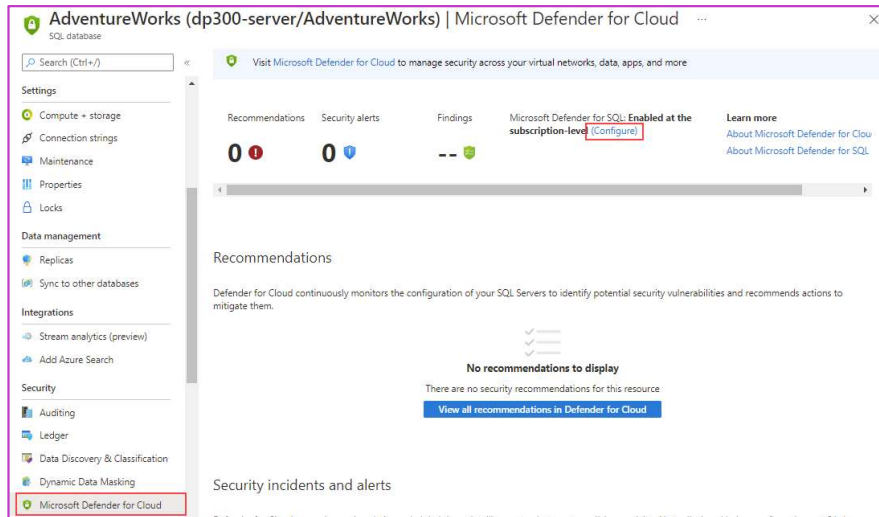
[Data Catalog](#) - Finds trusted data sources by browsing and searching your data assets. The data catalog aligns your assets with friendly business terms and data classification to identify data sources.

[Data Estate Insights](#) - Gives you an overview of your data estate to help you discover what kinds of data you have and where.

How to check for vulnerabilities in Azure SQL Database

Issues that Advanced Threat Protection identifies can be found in the "Microsoft Defender for Cloud" under "Security" section

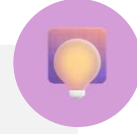
Vulnerability assessment is available when scanning results are stored in a storage account



© Copyright Microsoft Corporation. All rights reserved.

Enable Microsoft Defender for SQL for SQL Database or SQL Managed Instance from the server main blade by selecting **Microsoft Defender for Cloud**, and then the **(Configure)** link.

Knowledge check



Where is the data from data classification stored in SQL Server 2019?

- ☐ In the extended properties for each object
- ☒ In the sys.sensitivity_classifications catalog view
- ☐ In the sys.all_columns catalog view



Which is NOT an option to store vulnerability assessment data?

- ☐ Storage Account
- ☒ Physical disk
- ☐ Log Analytics



Which of the following features automate data discovery through the provision of data scanning and classification as a service?

- ☐ Database auditing
- ☐ Dynamic Data Masking
- ☒ Azure Purview

© Copyright Microsoft Corporation. All rights reserved.

1) Where is the data from data classification stored in SQL Server 2019?

- ✗ Fel: In the extended properties for each object**
Klassificering lagras inte i extended properties, utan i katalogvy.
- ✓ Rätt: In the sys.sensitivity_classifications catalog view**
Här lagras etiketter och informationsklassning för kolumner.
- ✗ Fel: In the sys.all_columns catalog view**
sys.all_columns visar kolumner, inte klassificeringsmetadata.

2) Which is NOT an option to store vulnerability assessment data?

- ✗ Fel: Storage Account**
Storage Account är ett giltigt mål för assessment-resultat.
- ✓ Rätt: Physical disk**
Fysisk disk är inget alternativ i Azure Vulnerability Assessment.
- ✗ Fel: Log Analytics**
Log Analytics kan lagra och analysera säkerhetsresultat.

3) Which feature automates data discovery and classification as a service?

- ✗ Fel: Database auditing**
Auditing loggar händelser, inte automatisk data discovery/klassning.
- ✗ Fel: Dynamic Data Masking**
DDM döljer data vid visning, inte discovery och klassificering.
- ✓ Rätt: Azure Purview**
Purview skannar datakällor och klassificerar data automatiskt.

Instructor led labs: Enable Microsoft Defender for SQL and Data Classification

**Enable Microsoft Defender for Azure SQL Database
Configure data classification and masking**

© Copyright Microsoft Corporation. All rights reserved.

<https://microsoftlearning.github.io/dp-300-database-administrator/Instructions/Labs/05-enable-sql-defender-and-data-classification.html>

References

Always Encrypted:

<https://learn.microsoft.com/sql/relationaldatabases/security/encryption/always-encrypted-database-engine?view=sql-server-ver15>

What is Azure Key Vault?

<https://learn.microsoft.com/azure/key-vault/general/basic-concepts>

Advanced Threat Protection for Azure SQL Database:

<https://learn.microsoft.com/azure/sql-database/sql-database-threat-detection-overview>

© Copyright Microsoft Corporation. All rights reserved.

Learning Path Recap

In this learning path, we:

Learned to configure database authentication and authorization, including Azure SQL Database authentication options, security principals, and roles in Azure SQL Database and SQL Server.

You also learned to protect data in-transit and at-rest by implementing Transparent Data Encryption, Always Encrypted, Dynamic Data Masking, and managing firewalls in Azure SQL Database.

Lastly, you explored implementing compliance controls for sensitive data, including data classification, Dynamic Data Masking, Advanced Threat Detection, Azure SQL Database Ledger, and Azure Purview.

© Copyright Microsoft Corporation. All rights reserved.



© Copyright Microsoft Corporation. All rights reserved.